

ISO 27001 assessment and SoA in CISO Assistant

✓ **Objective: an assessment that tells the truth, a marking that justifies it**

The lab: evaluate on one side, mark on the other

Clauses 4 to 10:
evaluate

30 requirements, an honest result and its observation

Annex A: mark applicability

71 controls across two themes, every exclusion justified

Session objectives

By the end of this lab, the working group's GRC tool instance contains: the initial compliance assessment, created in session 3 under whatever name the group gave it and filled in during session 4 on twelve Annex A controls only, now filled in on the 30 assessable requirements of clauses 4 to 10; and the « Déclaration d'applicabilité » (Statement of Applicability) block marked on the fifteen controls already investigated, the twelve from session 4 and the three new ones from the lecture, five being common to both lists, each non-applicable control carrying its written justification. The lab lasts 50 minutes, before lunch; the rest of Annex A is marked during supervised project time, if the group chooses to go all the way. What is also learned there:

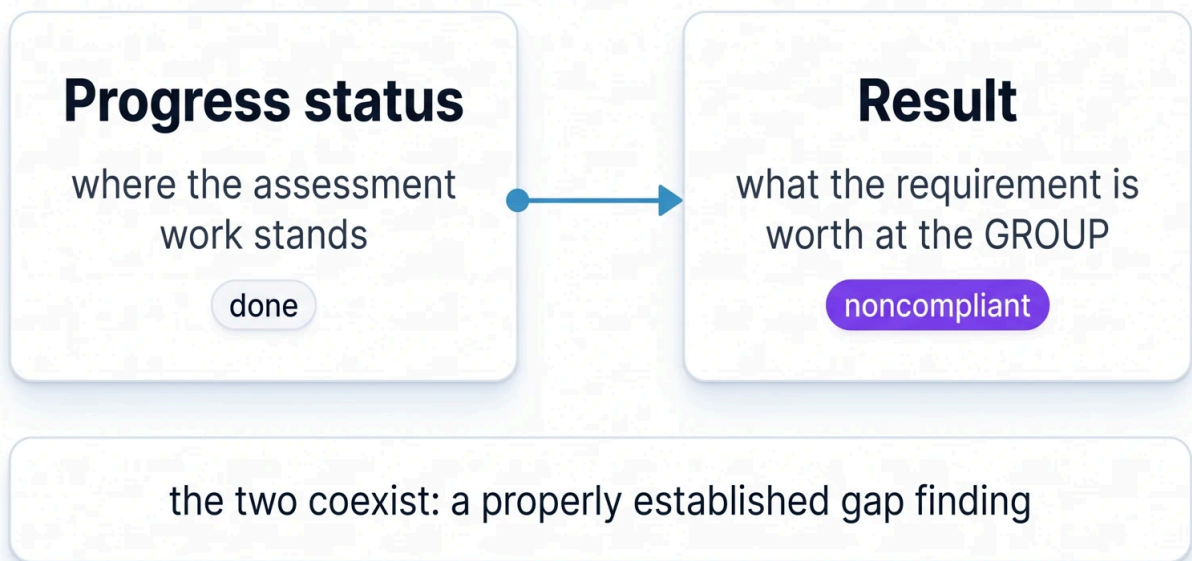
- **Distinguish** an assessment's progress (what remains to be done) from its result (what the requirement is worth), two pieces of information the tool separates and beginners confuse
- **Assess** a management requirement from the group's real deliverables, with neither complacency nor performative severity
- **Translate** into the tool the applicability statuses built in the lecture, justification included
- **Record** the figures that will feed deliverable D8 and the strategy note in the afternoon

Prerequisites

- The working group's CISO Assistant instance with the domain of the subsidiary under review created in session 2 and the assessment created in the session 3 lab, filled in during session 4: this whole lab works WITHIN the existing setup, nothing is recreated.
- The lecture: the architecture of the clauses, to be walked through line by line.
- The lecture, again: the applicability justification rules and the eight statuses built there.
- The session 4 audit report and the session 7 treatment plan, the exhibits for each assessment.

✓ The tool's vocabulary, set once and for all

Before touching the keyboard, put exact words on what is about to be handled, because the tool separates two things everyday language confuses. Each requirement in the assessment carries a PROGRESS STATE, which says where the assessor's work stands: to do, in progress, in review, done. And a RESULT, which says what the requirement is worth at MERIDIAN: compliant, partially compliant, noncompliant, not applicable, or not assessed as long as the assessor has not ruled. Progress speaks of the ASSESSOR, the result speaks of the GROUP. A requirement can be "done" on the progress side and "noncompliant" on the result side: that is even the most useful case, a properly established finding of a deviation. The opposite reflex, leaving everything at "not assessed" so as not to display any red, is the cardinal sin of the exercise: an assessment that says nothing protects no one, and the certification auditor will have no such reticence.



A third object, finally: each assessed requirement can carry an observation, a free-text field. That is where the justifications live, that of a severe result as well as that of a non-applicability. Group rule for this lab: no "noncompliant" or "not applicable" result without an observation of at least one sentence, traced to a piece of the file. A figure without justification gets forgotten; a written justification can be defended in the oral defense.

💡 Assess on evidence, not on impression. The question is never "do we look serious on this subject?" but "which deliverable, dated and named, proves this requirement is satisfied?". If the piece cannot be named, the result is at best "partially compliant". It is the discipline learned in the session 4 audit, applied this time requirement by requirement.

✓ Step 1: finding the assessment and checking its state (5 minutes)

1. **Find** in the working group's instance the initial compliance assessment, whatever name it bears, attached to the perimeter created in session 3 in the domain of the subsidiary under review and to the reference framework imported the same day.
2. **Check** before any entry that the tree does display the two blocks of the framework, clauses 4 to 10 on one side, the « Déclaration d'applicabilité » block on the other, and that clauses 4 to 10 are in their initial state, results not assessed, progress to do; Annex A already carries the twelve statuses entered in session 4, which step 3 will confirm or correct.

3. **Note down** on the lab sheet the starting count: 123 assessable requirements in total, of which 93 Annex A controls. If the counts differ, stop and fix the import before assessing anything; assessing a wrong framework means producing a wrong file.

Validation criterion: being able to say, without opening the help, which piece of information on the screen is a progress state and which is a result.

✓ Step 2: assessing clauses 4 to 10 with the file's evidence (30 minutes)

This is the heart of the lab. Walk through the clauses' assessable requirements in order, and for each: look for the piece of the MERIDIAN file that answers for it, decide the result, write the observation when the group rule requires it, and move the progress to "done". The lecture's correspondence table is the reading guide; here is its working version, deliberately incomplete, the results remaining to be decided:

Clauses	File evidence to confront	Question to ask
4.1 to 4.4, context	Session 2 mapping, regulatory context from sessions 1 and 3	Is the context described, up to date, and is the scope WRITTEN DOWN anywhere?
5.1 to 5.3, leadership	Session 1 governance: framing note, RACI matrix, and the appetite, for which session 1 set who sets it and session 5 the level	Is the commitment visible and documented, or lived but informal?
6.1 to 6.3, planning	Assessment from sessions 5 and 7, treatment plan, register	Does each risk have a decided treatment, an owner, a deadline?
7.1 to 7.5, support	Session 1 budget, GRC tool, documented deliverables	The resources exist, but is the documented information managed, versioned, findable?
8.1 to 8.3, operation	Implementation of the treatment plan in the subsidiaries	Is the plan in actual execution, or merely approved?
9.1 to 9.3, evaluation	Session 4 internal audit report	An audit took place; but who measures what, how often, and does management review the system?
10.1 and 10.2, improvement	Treatment of the audit deviations undertaken in session 7	Do nonconformities trigger traced corrective actions?

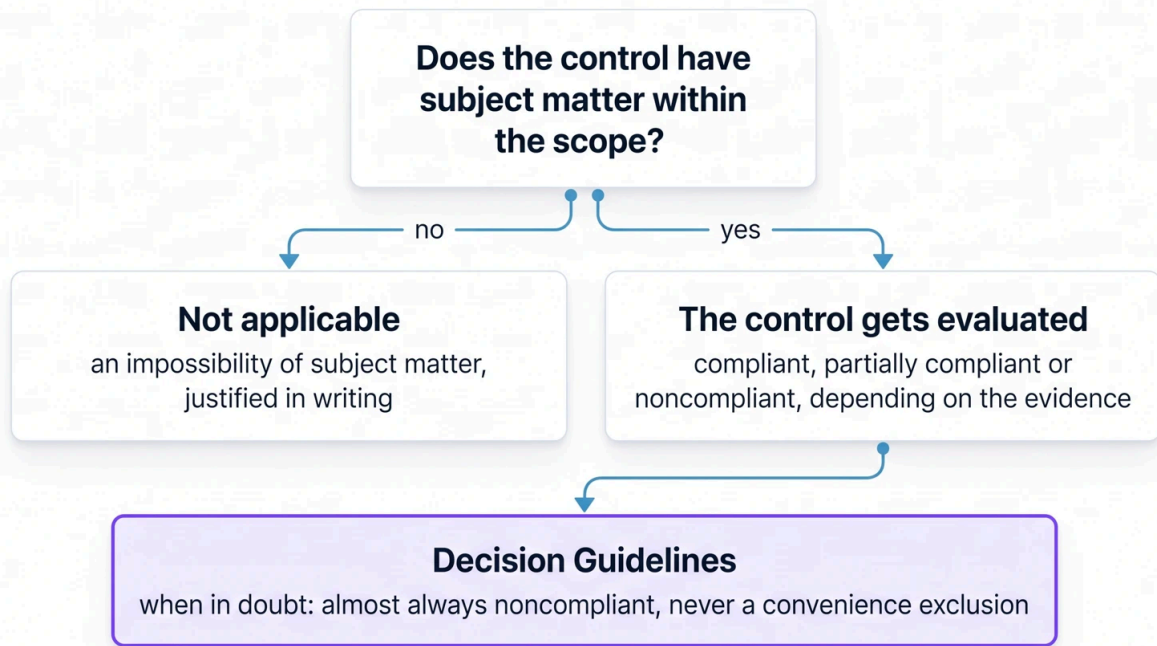
1. **Assess** the clauses' 30 assessable requirements, result and progress, with an observation for each noncompliant result; a partially compliant result needs no observation, time is short and D8 does not need it.
2. **Ban** two easy ways out from the session: the polite "compliant" (if the piece does not exist, the result goes down) and "not applicable" on a clause (clauses apply in full, as established this morning; that result only has legitimate meaning on Annex A).
3. **Note** as work proceeds, on the sheet, the two clauses that come out worst: that finding will serve this afternoon in the strategy note, and session 9 will answer it.

Validation criteria: no clause requirement left at "not assessed"; each "noncompliant" carries its observation; no "not applicable" in the clauses block.

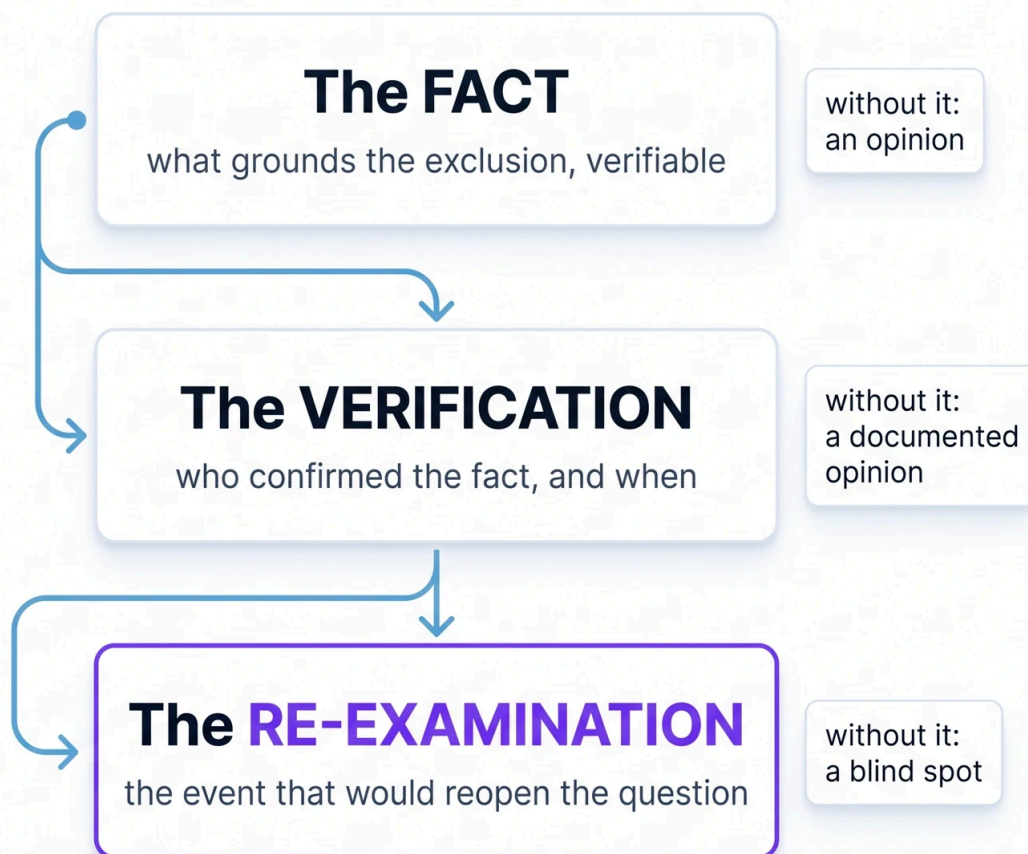
✓ Step 3: marking applicability on Annex A (15 minutes)

Next comes the « Déclaration d'applicabilité » block, limited before lunch to the fifteen controls already investigated: the eight from the lecture, to carry over, and the twelve from session 4, to confirm or correct with the day's rules, five controls being common to both lists. The 78 other Annex A controls are marked during supervised project time, for groups that want a complete statement; deliverable D8 only requires the investigated controls, with their coverage rate.

1. **Carry over** first the eight statuses built in the lecture, observations included: they are the eight calibrated controls, they set the pace and the level of demand for the justifications.
2. **Confirm** then the twelve controls entered in session 4, with the day's rules: for each, a "not applicable" result with written justification if the reality of the scope makes it moot, otherwise an honest implementation result, compliant, partially compliant or noncompliant, backed where possible by an audit deviation or a line of the treatment plan.
3. **Justify** each exclusion in three lines, in the observation of the control set to the "not applicable" result: the FACT founding the exclusion, the VERIFICATION of that fact, who confirmed it and when, and the re-examination CONDITION, the event that would reopen the question. Without the fact, the exclusion is an opinion; without the verification, a documented opinion; without the re-examination condition, a decision that will outlive its own validity. An exclusion whose fact has not been investigated is not written: the control stays included, noncompliant if need be. The D8 register of exclusions is that list, filtered in the tool.
4. **Apply** the lecture's discipline: no comfort exclusion; when hesitating between "noncompliant" and "not applicable", it is almost always "noncompliant", exclusion requiring an absence of object, not an absence of implementation.
5. **Record** for the sheet the counts: number of controls per result on the fifteen investigated controls, and the named list of the non-applicable controls with their one-line justification.



Validation criteria: the fifteen investigated controls carry a result; each "not applicable" carries its three-line justification, fact, verification, re-examination; the controls linked to the session 7 treatment plan are identifiable by their observation.



✓ Step 4: reading what the assessment tells (after lunch, opening the second lab)

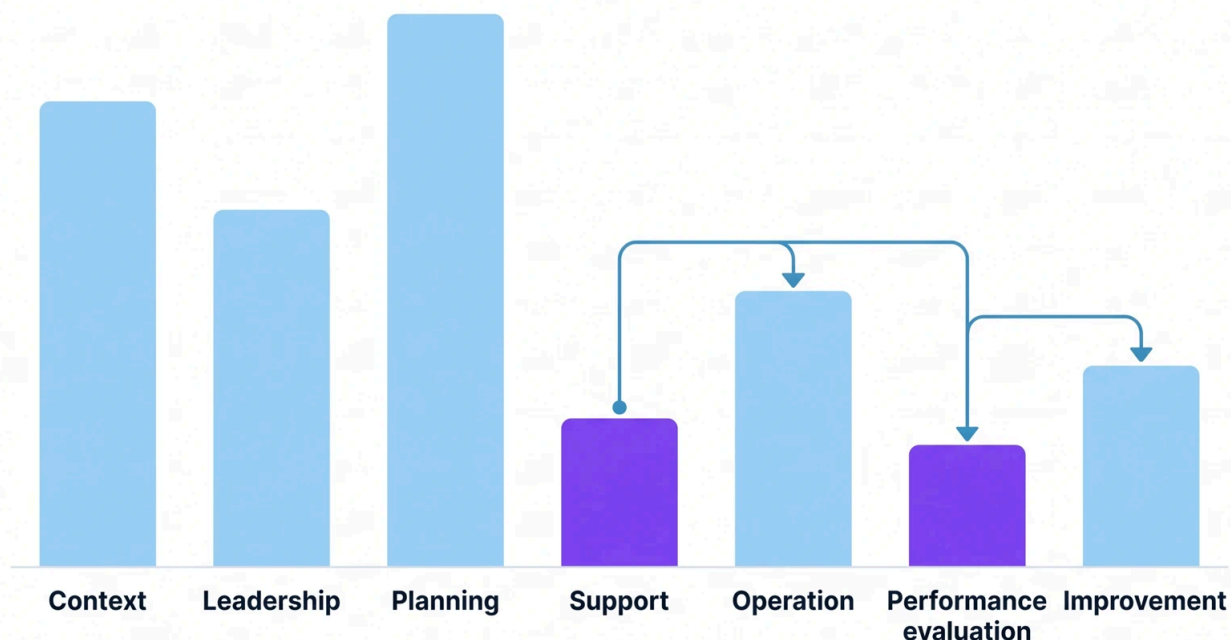
At the opening of the afternoon lab, five minutes of altitude are in order, because the figures produced tell a story and it will have to be told on Thursday.

1. **Compare** the profile of the clauses: which ones hold thanks to the work of the last eight weeks, which remain bare? If the assessment is honest, the context and planning clauses come out clearly better than documentary support and performance measurement: the module built in that order, and session 9 exists precisely to fill what remains.
2. **Formulate** in two sentences, on the sheet, the message for management: what the initial assessment says about the road traveled, and the work site it designates.

✓ Answer keys and assessment criteria

Answer key: the expected profile of the assessment

There is no single assessment correct to the decimal point, but there are defensible profiles and false ones. A defensible profile looks like this: the context clauses largely served by the mapping, with a caveat on the scope, discussed this morning but not yet formalized in a document, hence partially compliant; leadership carried by the session 1 governance, partially compliant until the consolidated policy arrives in session 9; planning robust, the treatment plan and the register being the freshest pieces of the file; support lagging, the documented information requirement being served only by scattered deliverables, with no overall document management; operation in progress, the treatment plan being approved but its execution only started; performance evaluation uneven, an internal audit did take place, but no monitoring or regular measurement exists yet, and no management review is institutionalized; improvement initiated by the treatment of the deviations, with no formalized nonconformity process. Two clauses therefore come out worst, documentary support and performance evaluation: if the assessment finds that, it says the same thing as the lecture's table, and the tool has just revealed why session 9 is titled "keeping the system alive". A false profile, conversely, is quickly recognized: everything compliant is politeness; everything noncompliant is posturing; and not-applicables in the clauses is a misreading of the standard.



On Annex A, the expectation is a handful of not-applicables at most, all justified by an absence of object in the scope, the case investigated in the tutorial being the prototype if it concluded in an absence of object; a batch of noncompliants linked to the session 4 audit deviations, the major deviations of the subsidiary under review (findings table of the reference pack) first among them; and a majority of partially compliants, which is the normal

profile of an organization that started with governance and risk analysis. If the marking counts twenty exclusions, reread each one: controls have almost certainly been excluded that should have been declared noncompliant.

Answer key: one exclusion justification that holds, and two that do not

The three-line model, applied at TRAMONTANE to the secure coding control: "Fact: no software development activity at TRAMONTANE, its services being operated on third-party software packages, the online store at its cloud provider and the WMS of the Rivesaltes warehouse published by a third party. Verification: confirmed by TRAMONTANE's IT Director on [date], with the mapping's application inventory in support. Re-examination: at the next management review or at any development project, the project process carrying this trigger." Three lines, three functions: the fact is verifiable, the verification is dated and named, the re-examination condition turns the exclusion into a living decision rather than a blind spot. For the subsidiary under review, the same template applies to the control left to be investigated in the tutorial, once the answer has been obtained.

Two counter-examples to know how to recognize, because they come back in every student paper and in many companies. "Not applicable: physical monitoring of the premises is the landlord's responsibility": that is a transfer of implementation, not an absence of object; the control remains applicable, its implementation rests on the lease contract and can be verified, and the exclusion would have masked a dependency on a third party, exactly what session 6 showed must be contractualized. "Not applicable: remote work is marginal in the group": marginal is not nonexistent; as long as a single remote access exists, the control applies, sized to reality, and the authentication deviation found in session 4 shows the subject is anything but moot.

Lab assessment criteria

Criterion	Insufficient	Expected	Excellent
Completeness	Requirements remain unassessed within the lab's scope	Clauses complete, fifteen investigated controls marked	Same, with the counts recorded and checked on the sheet
Traceability	Results without observations, or vague observations	Each unfavorable result justified toward a named piece	Same, with phrasings reusable as they are in D8
Accuracy of statuses	Progress and result confused, or not-applicables in the clauses	The two notions distinguished, exclusions reserved for Annex A	Same, and the noncompliant versus not-applicable hesitations settled by the rule
Overall reading	No message drawn from the figures	The two weak clauses identified and the management message formulated	Same, with the explicit link to the session 9 program
Register of exclusions	Comfort exclusions, or uninvestigated facts	Three lines per exclusion: fact, verification, re-examination	Same, with the volume of exclusions questioned and owned

After lunch, deliverable D8 assembles what the assessment has just produced, the group's strategy note gains its subsection on the ISMS scope, and then supervised project time opens.